

Exercício 3 — Pontuações CVE

Como as organizações podem usar CVEs e pontuações CVSS de forma eficaz para melhorar sua postura de segurança cibernética?

Discuta estratégias para integrar informações de CVE em programas de gerenciamento de vulnerabilidades.

3. Pontuações CVE (CVSS)

Como Usar CVEs e Pontuações CVSS de Forma Eficaz?

A pontuação CVSS é um número de **0 a 10** que indica o quão perigosa é uma vulnerabilidade. As organizações a utilizam para responder a uma pergunta simples: **qual vulnerabilidade corrijo primeiro?**

Pontuação	Severidade	Ação
9.0 – 10.0	Crítico	Corrigir imediatamente (24–72h)
7.0 – 8.9	Alto	Corrigir em 1–2 semanas
4.0 – 6.9	Médio	Corrigir no próximo ciclo de patches
0.1 – 3.9	Baixo	Agendar conforme disponibilidade

Estratégias para Integrar CVE no Programa de Gestão de Vulnerabilidades

1. Escaneie regularmente

Use ferramentas como Nessus, Qualys ou OpenVAS para detectar automaticamente quais CVEs afetam seu ambiente.

2. Priorize pelo contexto — não apenas pela pontuação

Um CVE com pontuação 9.0 em um servidor interno isolado pode ser menos urgente do que um CVE com pontuação 7.0 em um sistema exposto à internet.

Pergunte-se: - Este sistema está exposto à internet? - Existe um exploit público disponível? - Este sistema é crítico para o negócio?

3. Aplique patches rapidamente e documente tudo

Aplique patches dentro do SLA definido pela severidade. Registre sempre o que foi corrigido, quando e por quem — isso é essencial para auditorias e conformidade.

4. Monitore inteligência de ameaças

Acompanhe feeds como o **CISA KEV (Known Exploited Vulnerabilities)** para saber quais CVEs estão sendo ativamente explorados — esses sobem imediatamente para o topo da fila, independentemente da pontuação.

5. Revise e repita

O gerenciamento de vulnerabilidades é um ciclo, não uma tarefa única. Escanear → Priorizar → Corrigir → Verificar → Repetir.

Resumo

A pontuação CVSS diz quão grave é uma vulnerabilidade. O contexto diz quão urgente ela é. Use ambos juntos para tomar decisões inteligentes com recursos limitados.